

Penetration Testing Report

Mediroza General Hospital

Target: <https://medirozahospital.com>

Engagement Type: Black-box Penetration Test

Batch: B083 | Week 4

Duration: 5 Days

Prepared By: Muhammad Talha

Date: October 2, 2026

This report is the output of an authorized, controlled training engagement conducted for educational purposes under NetworkWalks' internship programme. All testing was performed against a target for which written authorization was granted. These techniques must never be applied to any system without explicit written permission from the owner.

1. Executive Summary

Networkwalks conducted an authorised black-box penetration test against Mediroza General Hospital's public-facing web infrastructure (<https://medirozahospital.com>) over a five-day engagement, structured around four milestones: Initial Access, Data Extraction, Critical Data Exposure Analysis, and Reporting.

Testing successfully achieved all milestone objectives. The Patient Portal login was bypassed using SQL injection (Milestone 1), yielding three confidential, password-protected patient pathology reports. All three document passwords were recovered via dictionary attack (Milestone 2). Metadata embedded in one report led to the discovery of an unauthenticated, publicly accessible database backup containing the hospital's complete staff and shareholder records (Milestone 3).

Two findings are rated Critical: the authentication bypass itself, and the exposed database backup, which discloses national ID numbers, salaries, and ownership/shareholder data for the entire organisation without requiring any authentication. Combined, these findings represent a severe breach of patient confidentiality and corporate data, with regulatory, financial and reputational consequences for the client.

The overall risk to Mediroza General Hospital from the issues identified in this assessment is rated CRITICAL. Immediate remediation is recommended, prioritised according to the risk ratings in Section 5.

Summary of Findings

ID	Finding	Milestone	Risk
F1	SQL Injection — Authentication Bypass (Patient Portal)	M1	Critical
F2	Unauthenticated Exposure of Full Database Backup (/old/)	M3	Critical
F3	Weak / Predictable Passwords on Confidential PDF Reports	M2	High
F4	Username Enumeration on Patient Portal Login	M1	Medium
F5	Sensitive Metadata Disclosure in Distributed PDF Documents	M3	Medium
F6	Staff Login Portal — Resistant to Tested Attacks	Supplementary	Informational

2. Scope and Methodology

2.1 Target & Scope

Target: <https://medirozahospital.com>

Engagement Type: Full black-box penetration test

Objective: Identify vulnerabilities, exploit them to demonstrate real impact, and document findings professionally

2.2 Rules of Engagement

- Testing limited strictly to the target domain (medirozahospital.com) and its subdomains.
- No social engineering was performed against hospital staff or patients.
- No denial-of-service (DoS) testing was performed.
- No testing was conducted outside the agreed scope.
- Written authorisation for security testing was provided by the client prior to engagement.

2.3 Methodology Overview

Testing followed a structured black-box methodology aligned to the engagement's four milestones:

- Milestone 1 — Initial Access: reconnaissance and exploitation of the Patient Portal authentication mechanism to retrieve confidential patient PDF reports.
- Milestone 2 — Data Extraction: analysis and cracking of the encryption protecting the retrieved PDF files.
- Milestone 3 — Critical Data Exposure: analysis of recovered file metadata leading to discovery of a further server-side data exposure.
- Milestone 4 — Reporting: documentation of findings, evidence, risk ratings and remediation guidance (this report).

2.4 Tools Used

- whois, nslookup, dnsrecon — domain and DNS reconnaissance
- nmap (Zenmap) — port and service enumeration, OS/service fingerprinting
- whatweb, curl — web technology and header fingerprinting
- theHarvester — OSINT subdomain and email enumeration
- Manual browser-based testing — authentication logic, input validation, SQL injection
- pdf2john + dictionary-attack tooling (Networkwalks Hash Calculator / Password Cracker) — PDF password recovery
- exiftool, qpdf — PDF metadata and encryption analysis

2.5 Reconnaissance Summary

Initial reconnaissance was performed against medirozahospital.com to map infrastructure, exposed services, and technology stack prior to active testing.

WHOIS

The domain is registered via Namecheap with registrant details fully redacted behind a privacy service (WithheldForPrivacy LLC). No actionable registrant information was obtained.

```

$ whois wh01s.icann.org
Domain Name: WH01S02AM05FTSL.COM
Registry Domain ID: 332328960_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.icann.org
Registrar URL: http://www.icann.org
Updated Date: 2026-09-14T22:42:52Z
Creation Date: 2026-09-14T22:42:52Z
Registry Expiry Date: 2026-09-14T22:42:52Z
Registrar: NameCheap, Inc.
Registrar IAN ID: 305
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.610.321.8701
Domain Status: clientTransferProhibited https://icann.org/epp/clientTransferProhibited
Name Server: DNS1.NAM01CHAM05FTSL.COM
Name Server: DNS2.NAM01CHAM05FTSL.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/eui/
Last update of whois database: 2026-09-28T12:46:43Z ooo

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the data in Versign Global Registry
Services ("Versign's") Whois database is provided by Versign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. Versign does not
warrant its accuracy. By submitting a Whois request, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to Versign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of Versign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. Versign reserves the right
to restrict your access to the Whois database in its sole discretion to ensure

```

Figure R.1 — WHOIS record for medirozahospital.com

DNS Enumeration (nslookup, dnsrecon)

DNS resolution confirmed the web server IP and revealed mail routing via a third-party provider (jellyfish.systems) and cPanel-based hosting via autodiscover SRV records.

The screenshot displays a Kali Linux desktop environment. In the foreground, a terminal window titled "kali@kali:~" shows a netcat listener on port 4444. It receives a connection from 199.168.201.16, which identifies itself as "medtronicahospital.com". The listener then displays the remote host's IP address, 199.168.201.16, and the connection is closed.

In the background, a "Terminal Emulator" window titled "kali@kali:~" shows a netcat client connecting to the listener on port 4444. The client successfully connects to 199.168.201.16 and identifies itself as "medtronicahospital.com".

The desktop background features a Kali Linux logo and the word "KALI" in a large, stylized font.

Figure R.2 — nslookup resolving medirozahospital.com to 199.188.201.16

[illegible]

Figure R.3 — *dnsrecon* output: MX records, SPF/DMARC, and cPanel autodiscover SRV records

Port & Service Scanning (nmap)

An intense nmap scan revealed only three open ports — DNS (53), HTTP (80) and HTTPS (443) — served by OpenResty. An NSE script flagged an unusual response from /evox/about, and every HTTP response returned the title "One moment, please...", consistent with a bot-detection/WAF interstitial.

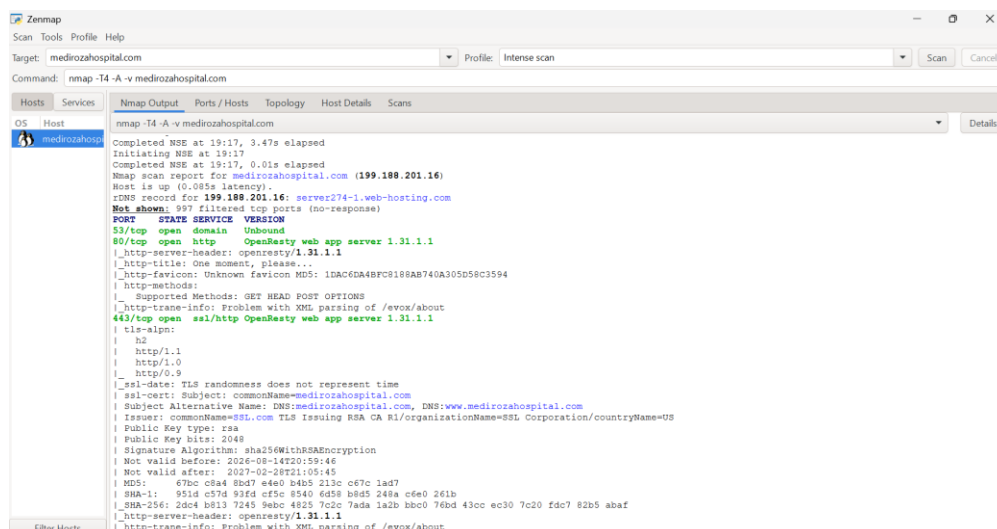


Figure R.4 — nmap service/version detection: OpenResty on 80/443, DNS on 53

Web Technology Fingerprinting (whatweb, curl)

whatweb confirmed the OpenResty backend and an edge-cache header. A later scan returned a 403 Forbidden response from a LiteSpeed-fronted layer, confirming active bot/WAF protection that intermittently blocked automated tooling (but not manual browser-based testing).

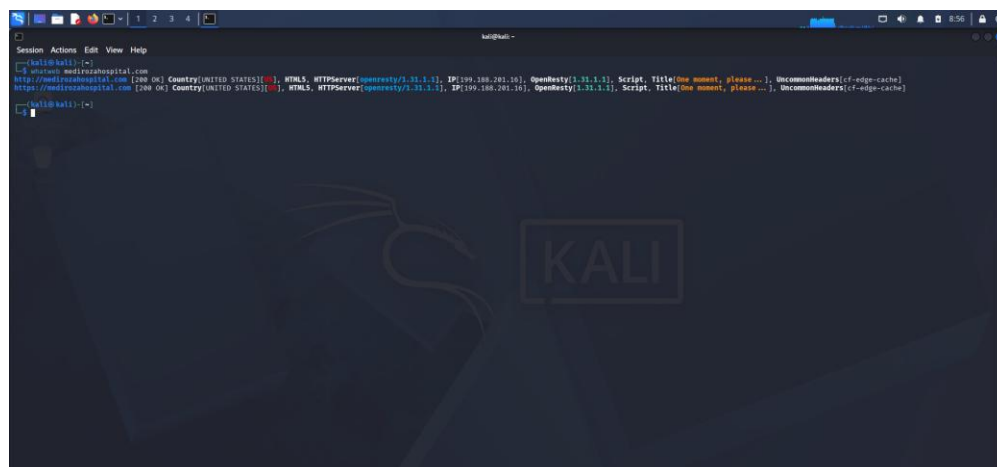


Figure R.5 — whatweb fingerprinting OpenResty backend

```
Session Actions Edit View Help
Registrant Phone: +1.3022861391
Registrant Fax:
Registrant Fax Ext:
Registrant Email: 38ab5dca311652da7367cc83354d984.protect@withheldforprivacy.com
Registrant ID:
Admin Name: Redacted for Privacy Purposes
Admin Organization: Privacy service provided by WITHHELD FOR PRIVACY LLC
Admin Street: 16192 Coastal Highway
Admin City: Lewes
Admin State/Province: Delaware
Admin Postal Code: 19958
Admin Country: US
Admin Phone: +1.3022861391
Admin Phone Ext:
Admin Fax:
Admin Fax Ext:
Admin Email: 38ab5dca311652da7367cc83354d984.protect@withheldforprivacy.com
Registrant Tech ID:
Tech Name: Redacted for Privacy Purposes
Tech Organization: Privacy service provided by WITHHELD FOR PRIVACY LLC
Tech Street: 16192 Coastal Highway
Tech City: Lewes
Tech State/Province: Delaware
Tech Postal Code: 19958
Tech Country: US
Tech Phone: +1.3022861391
Tech Fax:
Tech Fax Ext:
Tech Email: 38ab5dca311652da7367cc83354d984.protect@withheldforprivacy.com
Name Server: dns1.namescheaphosting.com
Name Server: dns2.namescheaphosting.com
DNSSEC: unsigned
URL of the ICANN WHOIS Data Problem Reporting System: http://wdprs.internic.net/
Last update of WHOIS database: 2026-09-28T01:38:02.04Z oow
For more information on Whois status codes, please visit https://icann.org/epp

kali@kali:~$ curl -s https://medirozahospital.com/
{"302 Moved Permanently"} Country[UNITED STATES]{0}, HTML5, HTTPServer[Litespeed], IP[199.188.201.16], Litespeed, RedirectLocation[https://medirozahospital.com/], Title[302 Moved Permanently][Title element contains no meta-information], UncommonHeaders{x-tor-bo-charged-by}
https://medirozahospital.com/ [403 Forbidden] Country[UNITED STATES]{0}, HTML5, HTTPServer[Litespeed], IP[199.188.201.16], Litespeed, PoweredBy[Litespeed], Title[403 Forbidden][Title element contains no meta-information], UncommonHeaders{x-tor-bo-charged-by}
```

Figure R.6 — Later whatweb run blocked with 403 Forbidden by WAF/bot protection

```
Minimize all open windows and show the desktop
kali@kali:~$ curl -I https://medirozahospital.com
HTTP/2 200
server: openresty/1.31.1.1
date: Mon, 28 Sep 2026 13:22:10 GMT
content-type: text/html
cache-control: private, no-cache, no-store, must-revalidate, max-age=0
cf-edge-cache: no-cache
```

Figure R.7 — curl -I showing response headers, including cf-edge-cache

OSINT Enumeration (theHarvester)

theHarvester identified additional subdomains (ftp.medirozahospital.com, mail.medirozahospital.com) and a contact email address, widening the known attack surface.

```
Session Actions Edit View Help
[*] Searching Urllscan.
[*] API unavailable, using fallback subdomain pattern search...
[*] Found 3 subdomains using DNS fallback
[*] Searching Windvane.
[*] Searching Yahoo.
[*] Searching Waybackarchive.
[*] No LinkedIn users found.

[*] LinkedIn Links found: 0

[*] IPs found: 2
199.188.201.16

[*] Emails found: 1
info@medirozahospital.com

[*] No people found.
[*] Hosts found: 2
ftp.medirozahospital.com
mail.medirozahospital.com

[*] Performing SecurityScorecard scan...
Read api-keys.yaml from /etc/theharvester/api-keys.yaml
An exception has occurred in SecurityScorecard scanning:
[*] Missing API key for SecurityScorecard.

[*] Performing BuiltWith scan...
Read api-keys.yaml from /etc/theharvester/api-keys.yaml
[*] Missing API key for BuiltWith.

kali@kali:~$
```

Figure R.8 — theHarvester results: hosts and email addresses discovered

2.6 Limitations

Automated reconnaissance tools (nmap, whatweb, curl) were intermittently blocked by a bot-detection/WAF layer in front of the application, which was not encountered during manual browser-based testing. This did not prevent any planned testing from being completed.

3. Findings and Proof of Exploitation

3.1 Milestone 1 — Initial Access (Patient Portal)

The homepage exposed two authentication entry points: a Patient Portal and a Staff Login, both discovered during initial reconnaissance.

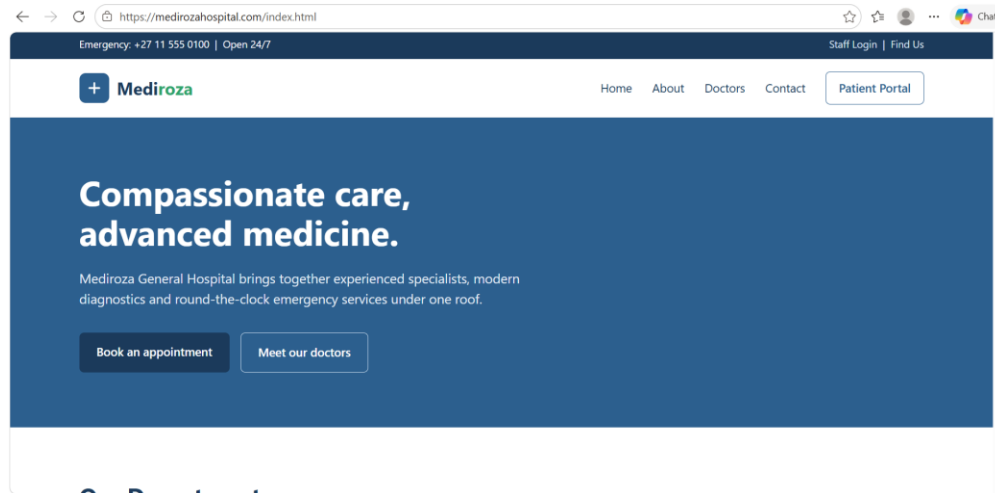


Figure M1.1 — Mediroza homepage showing Patient Portal and Staff Login entry points

F4 — Username Enumeration on Patient Portal Login

Risk Rating: Medium

The login form at `/patient/login.php` returns distinct error messages depending on whether a submitted username exists, allowing enumeration of valid accounts prior to further attack.

Evidence

- Submitting a random/invalid username returned: "Username not found".
- Submitting a known valid username (admin) with an incorrect password instead returned: "Incorrect password" — a different message, confirming enumeration.

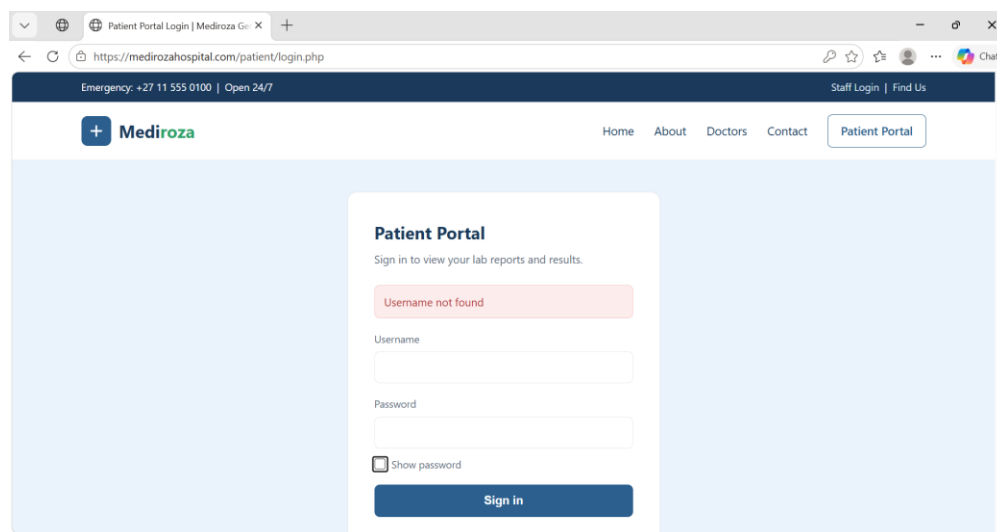


Figure M1.2 — "Username not found" response for a non-existent username

Impact

Enumeration of valid usernames significantly narrows the attack surface for credential stuffing, brute-force, and social engineering attacks.

F1 — SQL Injection — Authentication Bypass (Patient Portal)

Risk Rating: **Critical**

The Patient Portal login form does not sanitise or parameterise the username field before use in a backend database query. Submitting a classic SQL injection payload in the Username field allowed full authentication bypass without knowledge of a valid password.

Evidence / Proof of Exploitation

- Payload used: `admin' --` (with any value in the Password field).

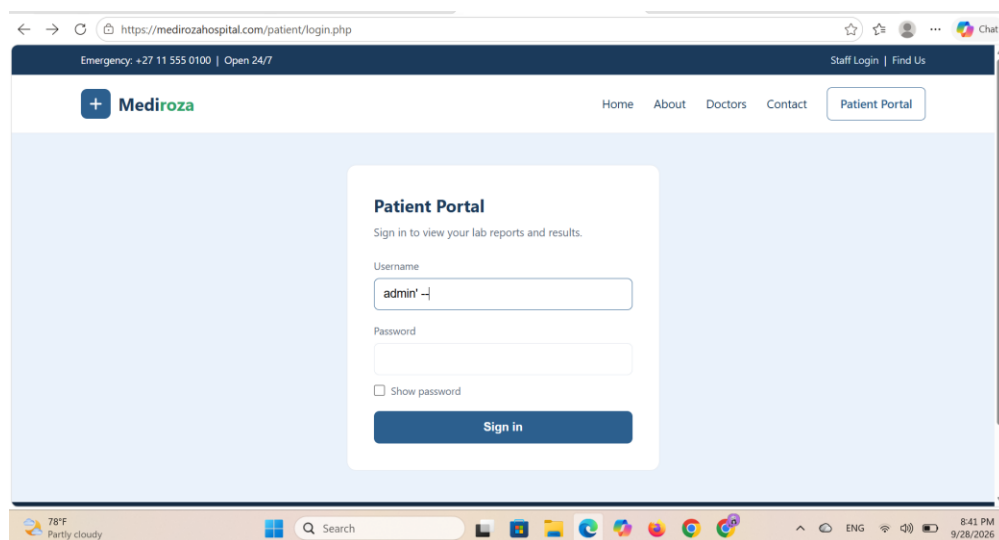


Figure M1.3 — SQL injection payload (`admin' --`) submitted in the Username field

- Result: successful authentication, redirecting to `/patient/portal.php` ('My lab reports').
- The portal exposed three confidential, password-protected patient pathology reports for download: `patient_report_1.pdf` (S. Dlamini, LR-2024-1187), `patient_report_2.pdf` (P. Reddy, LR-2024-1192), and `patient_report_3.pdf` (E. Thompson, LR-2024-1205).

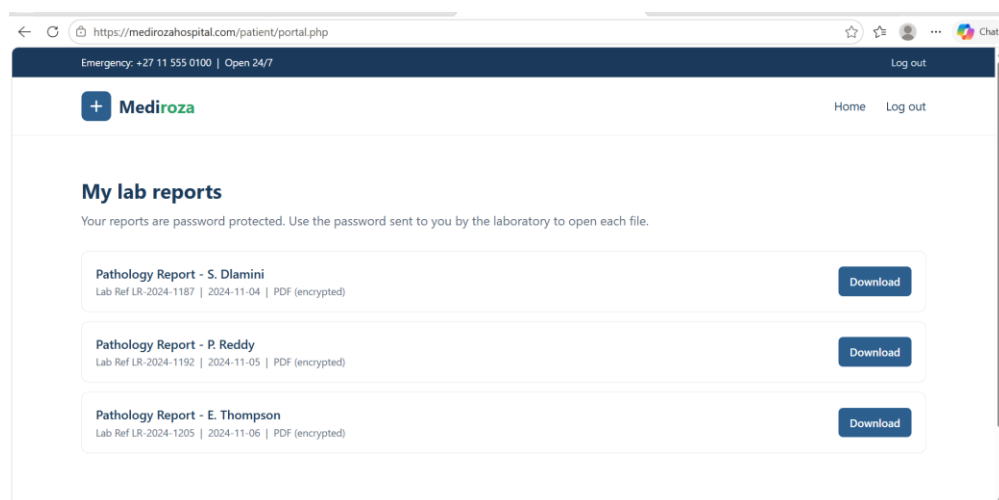


Figure M1.4 — Successful authentication bypass: 'My lab reports' page listing all three confidential patient PDFs

- View-source of the login page confirmed a plain POST form with no CSRF token and no visible server-side input validation.

Impact

An unauthenticated attacker can bypass login entirely and access any patient's confidential medical records without valid credentials. This constitutes a severe breach of patient confidentiality (PHI/medical data exposure) and would likely trigger data-protection regulatory obligations (e.g. POPIA in South Africa).

3.2 Milestone 2 — Data Extraction (Cracking PDF Encryption)

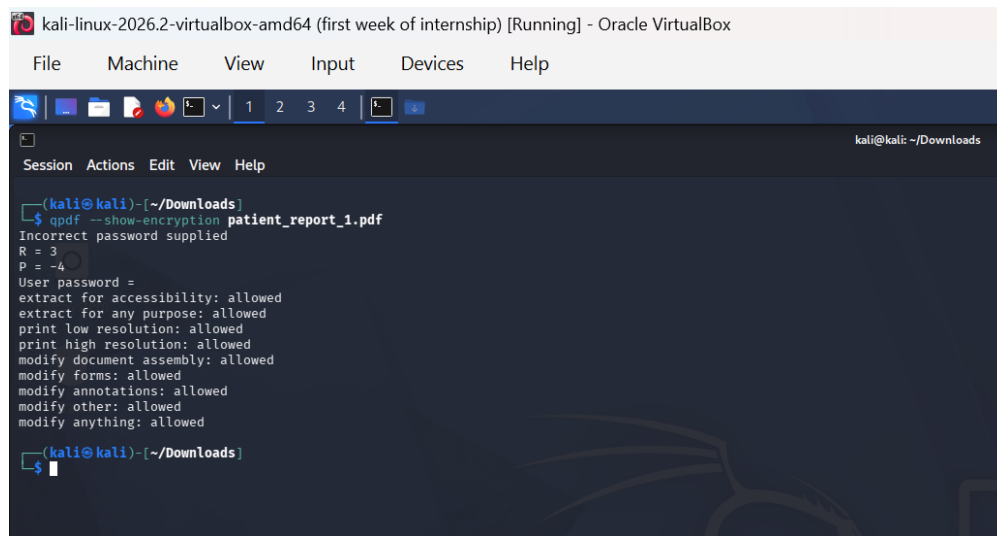
F3 — Weak / Predictable Passwords on Confidential Patient PDF Reports

Risk Rating: High

The three retrieved PDFs were encrypted using the PDF Standard Security Handler (RC4, 128-bit, Revision 3), requiring a user password to open each file. The engagement followed a four-step process to recover each password, applied individually to all three files since no single approach cracked all three equally quickly.

Step 1 — Confirm Encryption Type

qpdf was used to confirm the encryption scheme and permission set on each file before attempting recovery.



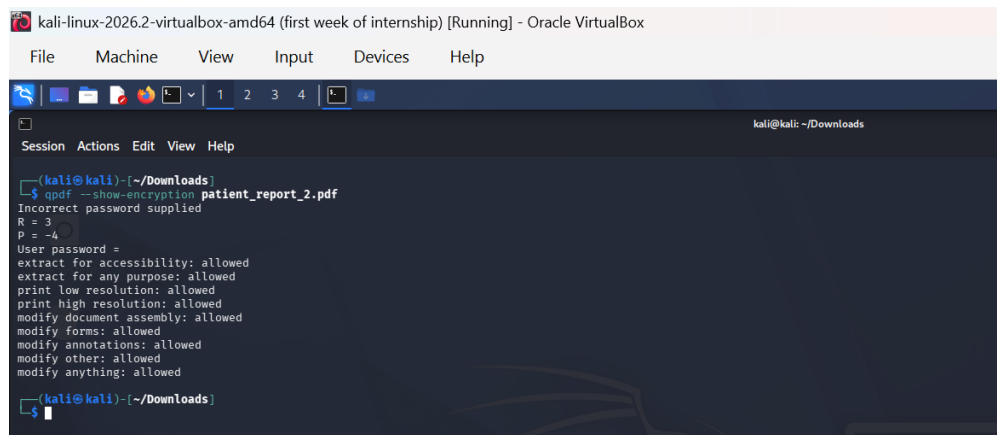
```
kali-linux-2026.2-virtualbox-amd64 (first week of internship) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~/Downloads
Session Actions Edit View Help

(kali@kali)-[~/Downloads]
$ qpdf --show-encryption patient_report_1.pdf
Incorrect password supplied
R = 3
P = -4
User password =
extract for accessibility: allowed
extract for any purpose: allowed
print low resolution: allowed
print high resolution: allowed
modify document assembly: allowed
modify forms: allowed
modify annotations: allowed
modify other: allowed
modify anything: allowed

(kali@kali)-[~/Downloads]
$
```

Figure M2.1 — patient_report_1.pdf encryption details (qpdf --show-encryption)



```
kali-linux-2026.2-virtualbox-amd64 (first week of internship) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~/Downloads
Session Actions Edit View Help

(kali@kali)-[~/Downloads]
$ qpdf --show-encryption patient_report_2.pdf
Incorrect password supplied
R = 3
P = -4
User password =
extract for accessibility: allowed
extract for any purpose: allowed
print low resolution: allowed
print high resolution: allowed
modify document assembly: allowed
modify forms: allowed
modify annotations: allowed
modify other: allowed
modify anything: allowed

(kali@kali)-[~/Downloads]
$
```

Figure M2.2 — patient_report_2.pdf encryption details

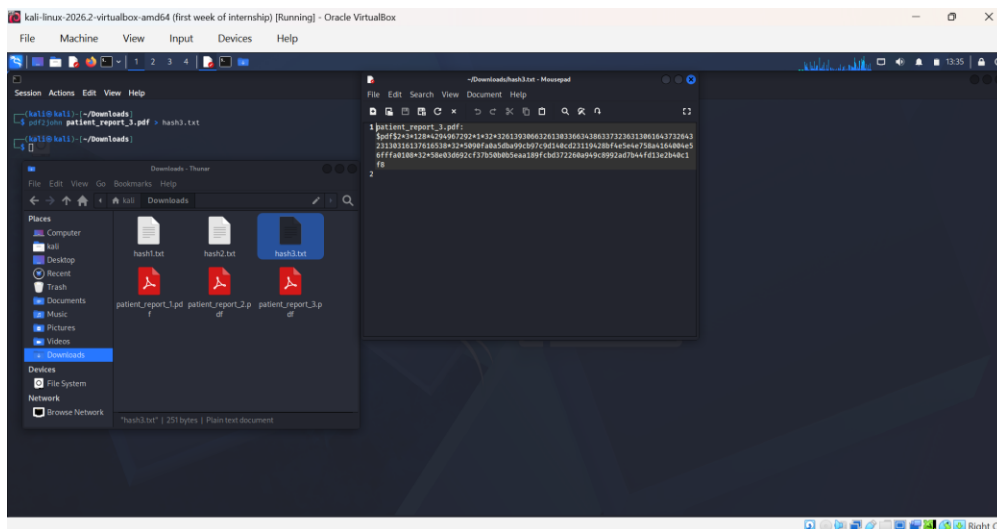


Figure M2.6 — Hash extracted from patient_report_3.pdf

Step 3 — Dictionary Attack

Each hash was run through a dictionary-based password-cracking attack.

- patient_report_1.pdf (Sipho Dlamini) — password cracked instantly: 123456

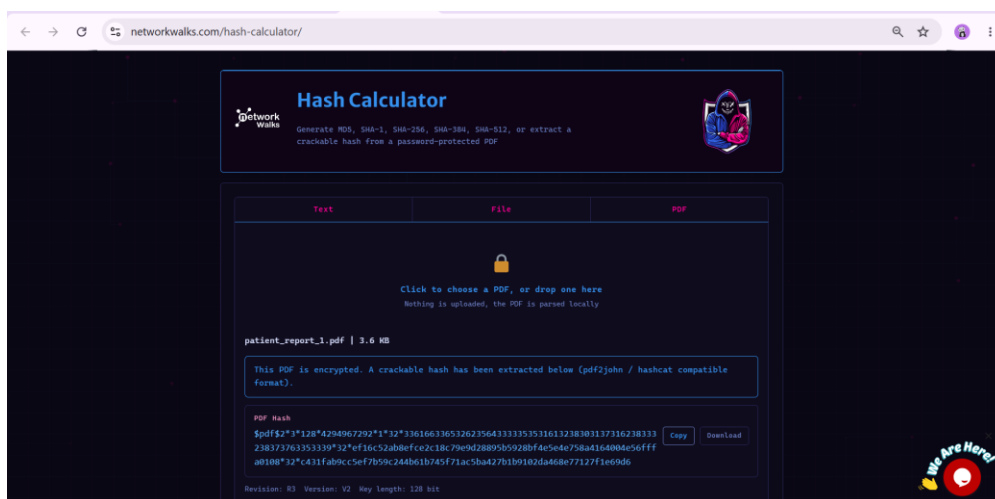


Figure M2.7 — PDF hash calculated for patient_report_1.pdf

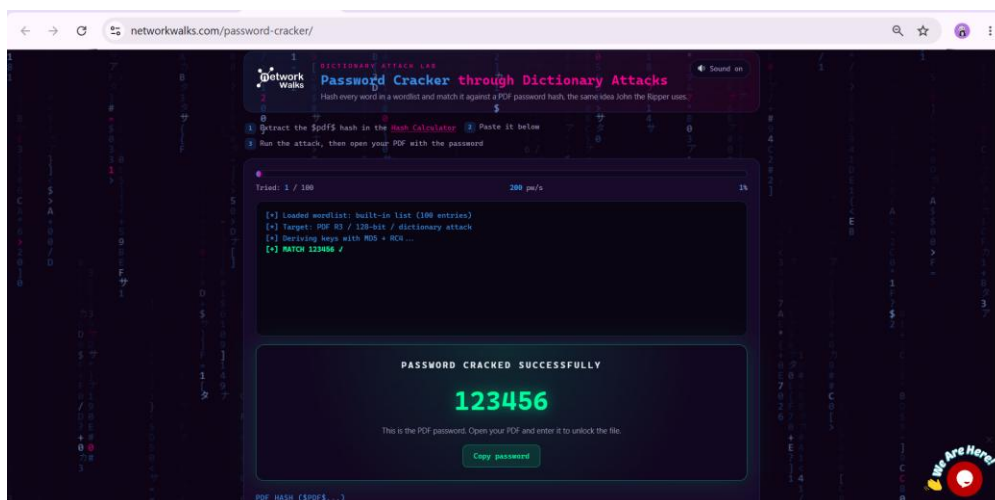


Figure M2.8 — Password 123456 recovered for patient_report_1.pdf

- patient_report_2.pdf (Priya Reddy) — password cracked instantly: password

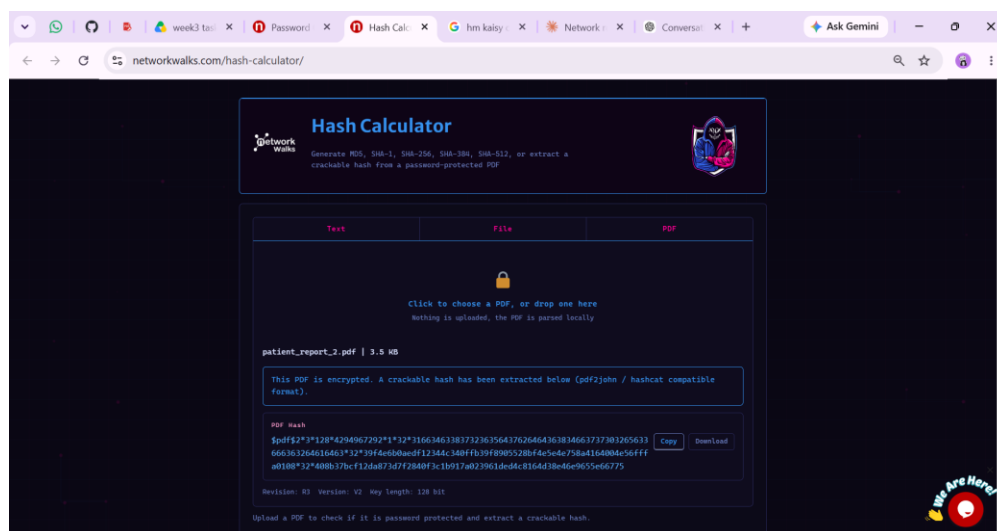


Figure M2.9 — PDF hash calculated for patient_report_2.pdf

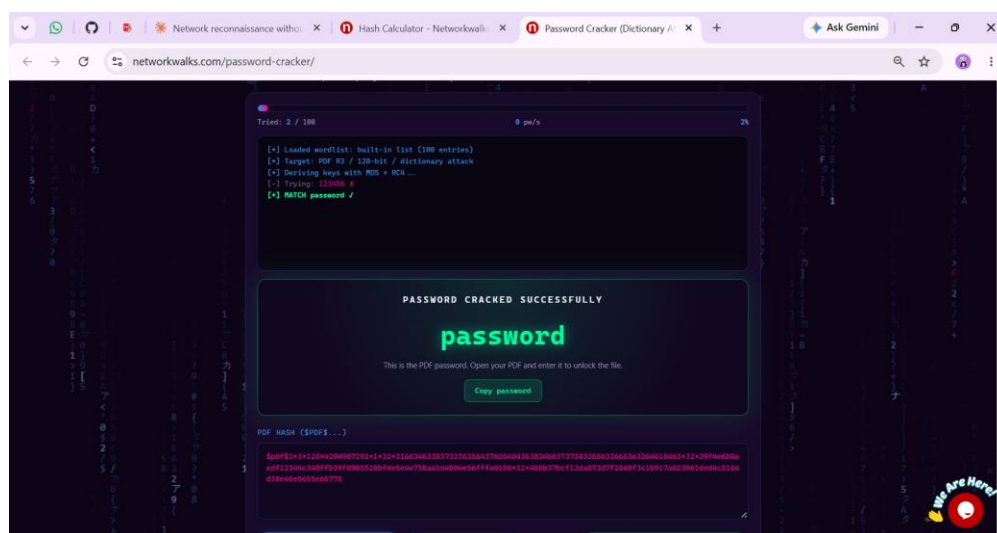


Figure M2.10 — Password 'password' recovered for patient_report_2.pdf

- patient_report_3.pdf (Emily Thompson) — required an extended dictionary attack (3,546 of 3,556 candidates tried): !@#%\$^&

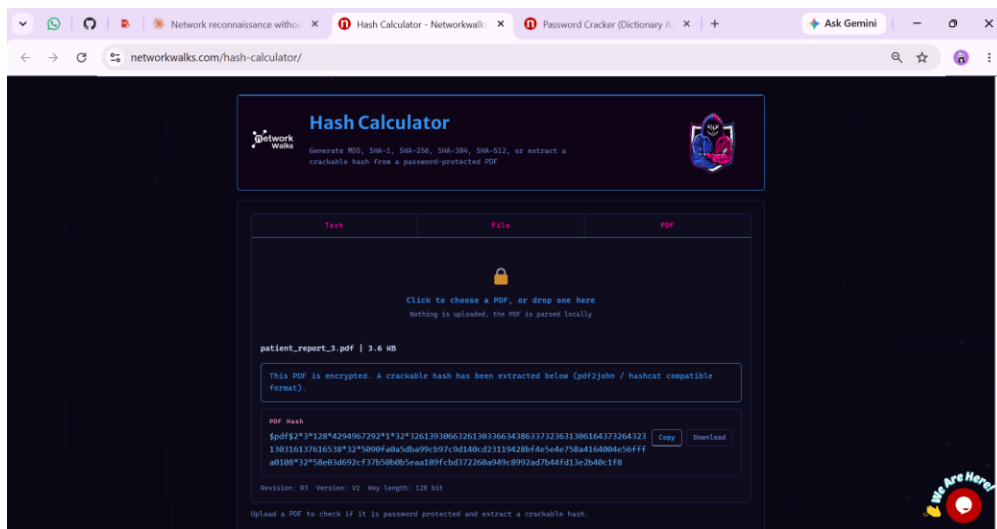


Figure M2.11 — PDF hash calculated for patient_report_3.pdf

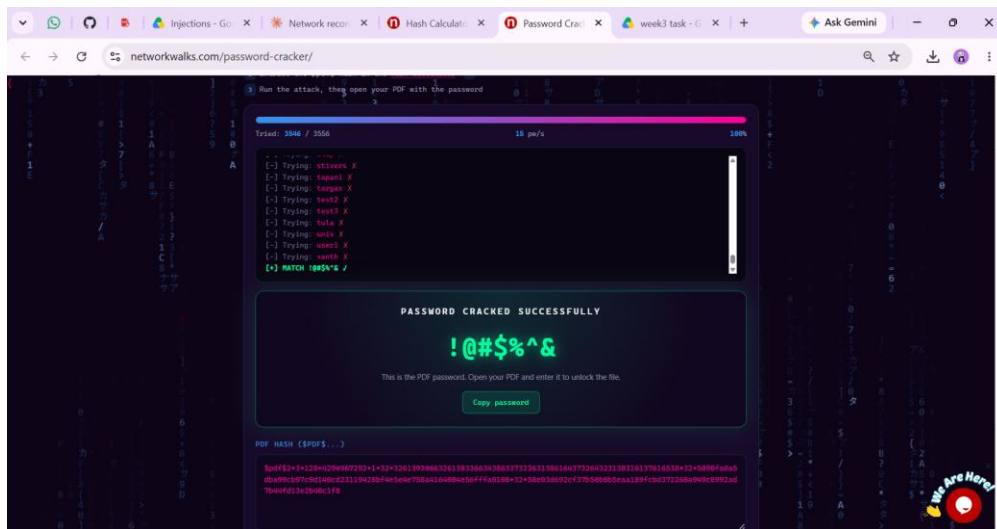
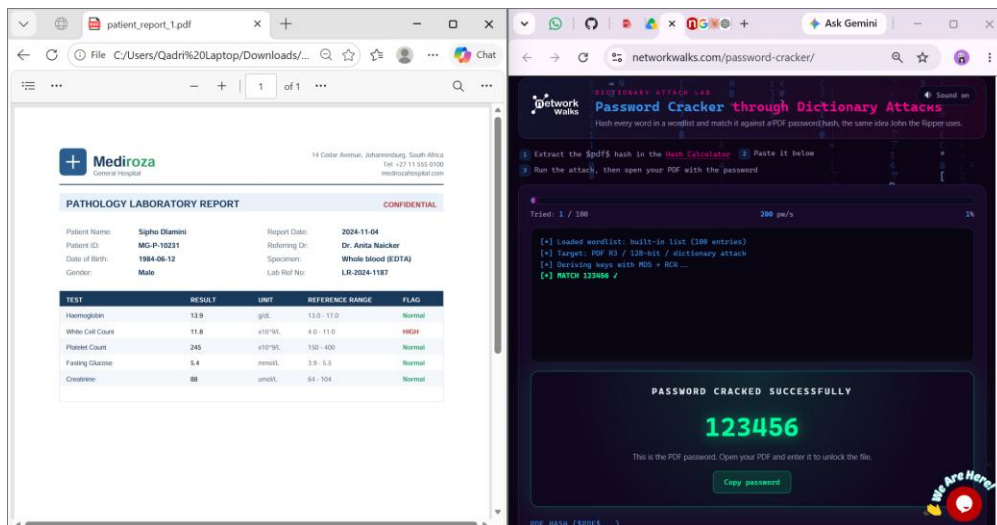


Figure M2.12 — Password !@#\$\$%^& recovered for patient_report_3.pdf after extended attack

Step 4 — Verification

Each recovered password was used to successfully open its corresponding file, confirming full recovery of content.



The image consists of two side-by-side screenshots. The left screenshot shows a terminal window with a dark background. At the top, it says "Tryied: 2 / 100" and "0 pa/s". The terminal output shows a list of loaded wordlists, a target PDF file, and the successful cracking of a password. Below the terminal, a PDF viewer shows a document titled "PASSWORD CRACKED SUCCESSFULLY" with the word "password" in large green letters. The right screenshot shows a web browser displaying a medical report from Mediroza. The report is titled "PATHOLOGY LABORATORY REPORT" and is marked "CONFIDENTIAL". It contains patient information (Priya Reddy, MG-P-10244) and a table of test results for cholesterol, LDL, HDL, triglycerides, and fasting glucose, all of which are within normal ranges.

[illegible]

Documents are encrypted, trivially weak or guessable passwords provide negligible real-world protection to a hacker who has already obtained the file (e.g. via F1 or email interception). Two of three files were encrypted with passwords worldwide.

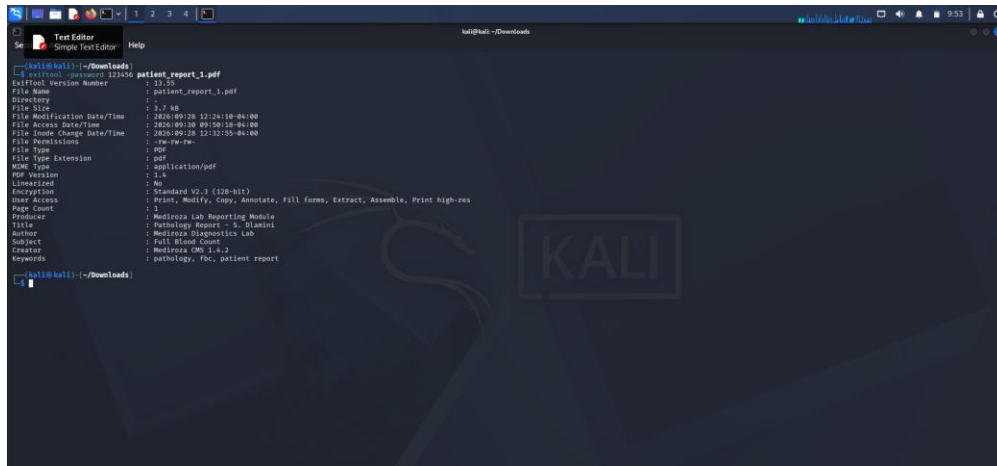
Even where documents are encrypted, trivially weak or guessable passwords provide negligible real-world protection against an attacker who has already obtained the file (e.g. via F1 or email interception). Two of three files used top-10 most common passwords worldwide.

3.3 Milestone 3 — Critical Data Exposure

F5 — Sensitive Metadata Disclosure in Distributed PDF Documents

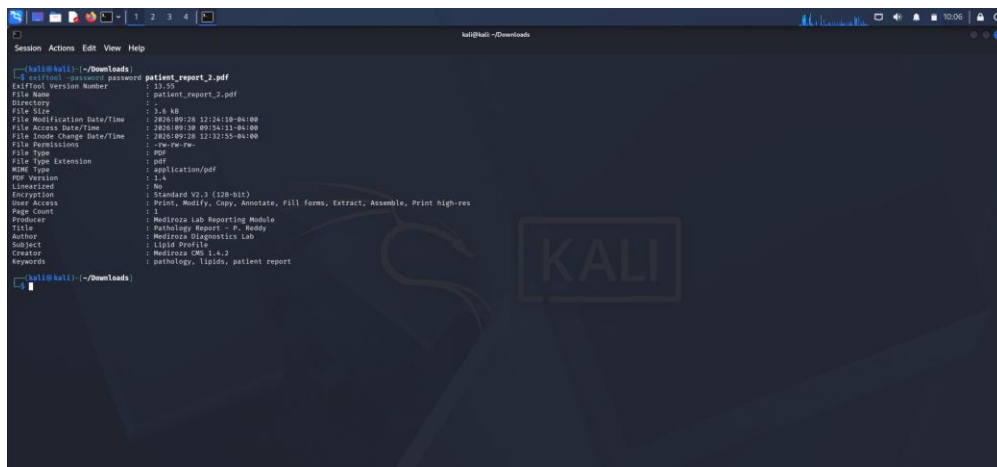
Risk Rating: **Medium**

Once decrypted, each PDF's embedded metadata (Author, Producer, Comments) was examined using exiftool. This is not visible when the document is viewed normally.



```
kali@kali: ~/Downloads
└─$ exiftool patient_report_1.pdf
ExifTool Version Number : 12.55
File Name                : patient_report_1.pdf
File Size                : 1.7 kB
Directory                :
File Modification Date/Time : 2020:09:28 12:14:18-04:00
File Access Date/Time    : 2020:09:28 09:10:18-04:00
File Inode Change Date/Time : 2020:09:28 12:12:55-04:00
File Permissions         : -rw-rw-rw-
File Type                : pdf
File Type Extension      : pdf
MIME Type                : application/pdf
PDF Version              : 1.4
Linearized               : No
Standard V2.3 (128-bit) :
Encryption              :
User Access              :
Page Count               : 1
Producer                : Mediroza Lab Reporting Module
Title                   : Pathology Report - S. Ramani
Author                  : Mediroza Diagnostics Lab
Subject                 : Full Blood Count
Creator                 : Mediroza QMS 1.4.2
Keywords                 : pathology, fbc, patient report
```

Figure M3.1 — Metadata for patient_report_1.pdf (standard fields, generic author)



```
kali@kali: ~/Downloads
└─$ exiftool patient_report_2.pdf
ExifTool Version Number : 12.55
File Name                : patient_report_2.pdf
File Size                : 2.6 kB
Directory                :
File Modification Date/Time : 2020:09:28 12:14:18-04:00
File Access Date/Time    : 2020:09:28 09:14:11-04:00
File Inode Change Date/Time : 2020:09:28 12:12:55-04:00
File Permissions         : -rw-rw-rw-
File Type                : pdf
File Type Extension      : pdf
MIME Type                : application/pdf
PDF Version              : 1.4
Linearized               : No
Standard V2.3 (128-bit) :
Encryption              :
User Access              :
Page Count               : 1
Producer                : Mediroza Lab Reporting Module
Title                   : Pathology Report - P. Reddy
Author                  : Mediroza Diagnostics Lab
Subject                 : Lipid Profile
Creator                 : Mediroza QMS 1.4.2
Keywords                 : pathology, lipids, patient report
Comments                : DB backup moved to /old before site migration, do not delete.
```

Figure M3.2 — Metadata for patient_report_2.pdf (standard fields, generic author)

- patient_report_3.pdf stood out: its Author field read 'j.malik' (a real internal staff username) instead of the generic 'Mediroza Diagnostics Lab' used on the other two files, and it carried an additional Comments field: "DB backup moved to /old before site migration, do not delete."

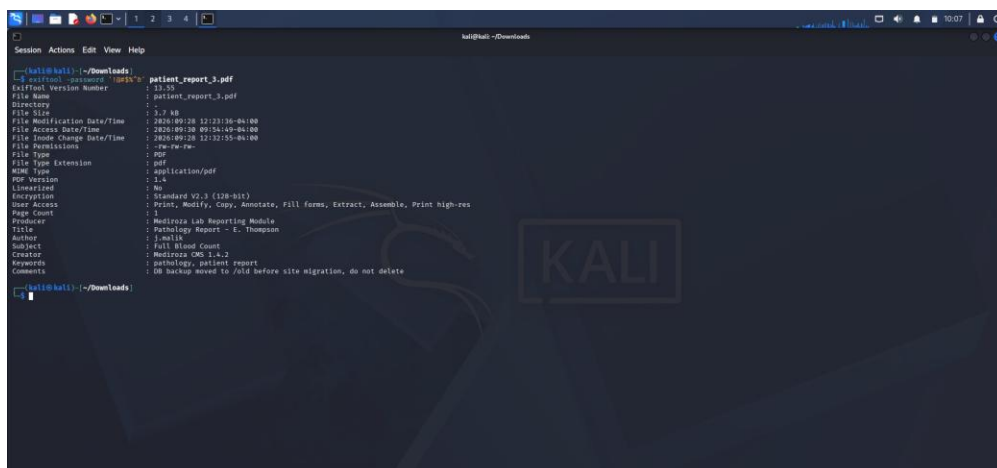


Figure M3.3 — patient_report_3.pdf metadata revealing Author 'j.malik' and the Comments field leaking the /old/ backup location

Impact

Metadata unintentionally retained in distributed documents can leak internal usernames, operational notes, and software versioning information. In this engagement, it directly led to the discovery of F2 below — demonstrating how a minor information-disclosure issue can chain into a critical data breach.

F2 — Unauthenticated Exposure of Full Database Backup via /old/ Directory

Risk Rating: Critical

Acting on the metadata lead from F5, the referenced path was requested directly. It resolved to an open, unauthenticated directory listing containing a full SQL database backup.

Evidence / Proof of Exploitation

- Navigating to <https://medirozahospital.com/old/> returned an open directory listing (LiteSpeed web server) containing mediroza_db_backup_2019.sql, downloadable without any authentication.

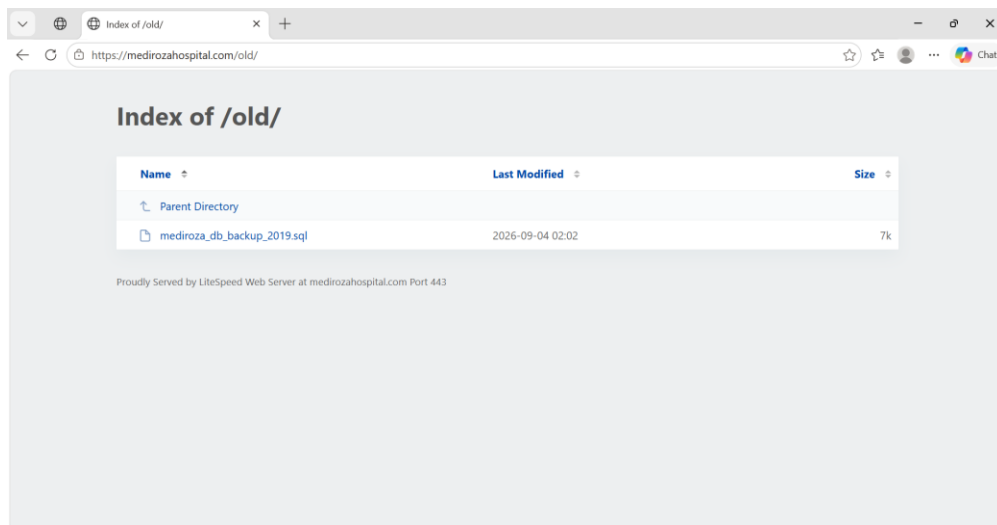


Figure M3.4 — Open, unauthenticated directory listing at /old/ exposing mediroza_db_backup_2019.sql

- The SQL dump's header confirmed it as an internal Mediroza General Hospital HR database backup, explicitly commented as containing 'confidential staff and shareholder records'. It contained a complete 'staff' table: 30 records with full name, job title, department, email, phone, national ID number, monthly salary (ZAR), and date joined.

```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CPE 3.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING! contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

-- Table structure for table 'staff'
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

-- Dumping data for table 'staff'
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`, `full_name`, `job_title`, `department`, `email`, `phone`, `national_id`, `monthly_salary`, `date_joined`) VALUES
(1, 'Dr. Rajesh Naidoo', 'Chief Pathologist', 'Diagnostics Lab', 'r.naidoo@medirozahospital.com', '+27 82 101 2007', '85021013011001', 130000, '2009-03-16'),
(2, 'Sarah Botha', 'Chief Financial Officer', 'Finance', 's.botha@medirozahospital.com', '+27 82 102 2014', '85011021022002', 152000, '2011-07-01'),
(3, 'Dr. Johan van der Merwe', 'Medical Director', 'Management', 'j.merwe@medirozahospital.com', '+27 82 103 2021', '85041031031003', 160000, '2007-01-22'),
(4, 'Dr. Anita Naicker', 'Consultant Cardiologist', 'Cardiology', 'a.naicker@medirozahospital.com', '+27 82 104 2028', '85051041040004', 132000, '2012-09-10'),
(5, 'Dr. Ahmed Kara', 'Consultant Physician', 'Internal Medicine', 'a.kara@medirozahospital.com', '+27 82 105 2035', '85061051050005', 120000, '2013-02-18'),
(6, 'Dr. Yusuf Cassim', 'Senior Registrar', 'Emergency & Trauma', 'y.cassim@medirozahospital.com', '+27 82 106 2042', '85071061060006', 74000, '2018-05-04'),
(7, 'Michael Roberts', 'HR Director', 'Human Resources', 'm.roberts@medirozahospital.com', '+27 82 107 2049', '85081071070007', 90000, '2020-11-15'),
(8, 'Susan Pretorius', 'HR Officer', 'Human Resources', 's.pretorius@medirozahospital.com', '+27 82 108 2056', '85091081080008', 32000, '2016-08-23'),
(9, 'Jameel Malik', 'IT Systems Administrator', 'IT', 'j.malik@medirozahospital.com', '+27 82 109 2063', '85101091090009', 50000, '2015-04-12'),
(10, 'Thabo Ndlefe', 'Network Engineer', 'IT', 't.ndlefe@medirozahospital.com', '+27 82 110 2070', '85111101101001', 46000, '2017-10-02'),
(11, 'Bonvula Khumalo', 'Registered Nurse', 'Emergency & Trauma', 'n.khumalo@medirozahospital.com', '+27 82 111 2077', '85121111121002', 34000, '2016-01-19'),
(12, 'Lerato Ndumbe', 'Registered Nurse', 'Pediatrics', 'l.ndumbe@medirozahospital.com', '+27 82 112 2084', '85011121121003', 33000, '2017-06-07'),
(13, 'Bongani Ndlovu', 'Registered Nurse', 'Cardiology', 'b.ndlovu@medirozahospital.com', '+27 82 113 2091', '85021131131004', 35000, '2015-12-01'),
(14, 'Zameel Mahlangu', 'Nursing Sister', 'Theatre', 'z.mahlangu@medirozahospital.com', '+27 82 114 2098', '85031141140005', 42000, '2013-03-25'),
(15, 'Kagiso Sithole', 'Pharmacist', 'Pharmacy', 'k.sithole@medirozahospital.com', '+27 82 115 2105', '85041151150006', 41000, '2014-09-08'),
(16, 'Naledi Zulu', 'Pharmacy Assistant', 'Pharmacy', 'n.zulu@medirozahospital.com', '+27 82 116 2112', '85051161160007', 26000, '2019-02-14'),
(17, 'Thembu Msooi', 'Radiographer', 'Radiology', 't.msooi@medirozahospital.com', '+27 82 117 2119', '85061171170008', 44000, '2016-07-30'),
(18, 'Palana Radebe', 'Radiographer', 'Radiology', 'p.radebe@medirozahospital.com', '+27 82 118 2126', '85071181180009', 43000, '2017-04-13'),
(19, 'Deepak Pillay', 'Lab Technologist', 'Diagnostics Lab', 'd.pillay@medirozahospital.com', '+27 82 119 2133', '85081191190010', 41000, '2015-05-20'),
(20, 'Kavitha Govender', 'Lab Technician', 'Diagnostics Lab', 'k.govender@medirozahospital.com', '+27 82 120 2140', '85091201200011', 35000, '2018-08-06'),
(21, 'Dr. Suresh Moodley', 'Consultant Radiologist', 'Radiology', 's.moodley@medirozahospital.com', '+27 82 121 2147', '85101211210012', 130000, '2012-02-28'),
(22, 'Dr. Fatima Patel', 'Pediatrician', 'Pediatrics', 'f.patel@medirozahospital.com', '+27 82 122 2154', '85111221220013', 110000, '2013-10-17'),
(23, 'Nisha Singh', 'Physiotherapist', 'Rehabilitation', 'n.singh@medirozahospital.com', '+27 82 123 2161', '85121231230014', 48000, '2016-11-09'),
(24, 'Dr. Vikram Chetty', 'Anesthetist', 'Theatre', 'v.chetty@medirozahospital.com', '+27 82 124 2168', '85011241240015', 51000, '2011-06-13'),
(25, 'David Smith', 'Facilities Manager', 'Operations', 'd.smith@medirozahospital.com', '+27 82 125 2175', '85021251250016', 52000, '2014-01-27'),
(26, 'Karen O'Connor', 'Billing Administrator', 'Finance', 'k.oconnor@medirozahospital.com', '+27 82 126 2182', '85031261260017', 29000, '2018-03-19'),
(27, 'James Wilson', 'Security Supervisor', 'Operations', 'j.wilson@medirozahospital.com', '+27 82 127 2189', '85041271270018', 27000, '2019-09-02'),
(28, 'Linda Fourie', 'Receptionist', 'Front Office', 'l.fourie@medirozahospital.com', '+27 82 128 2196', '85051281280019', 19000, '2020-02-10'),
(29, 'Peter van Wyk', 'Procurement Officer', 'Supply Chain', 'p.vanwyk@medirozahospital.com', '+27 82 129 2203', '85061291290020', 38000, '2015-08-24'),
(30, 'Anelise Manki', 'Hard Clerk', 'Administration', 'a.manki@medirozahospital.com', '+27 82 130 2210', '85071301300021', 21000, '2019-11-09');
UNLOCK TABLES;

--
-- Table structure for table 'shareholders'
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`, `shareholder_name`, `share_percent`, `shares_held`, `share_class`) VALUES
(1, 'Dr. Rajesh Naidoo', 18.0, 180000, 'Ordinary'),
(2, 'Cedar Health Holdings (Pty) Ltd', 15.0, 150000, 'Ordinary'),
(3, 'Dr. Johan van der Merwe', 12.0, 120000, 'Ordinary'),
(4, 'Reddy Family Trust', 11.0, 110000, 'Ordinary'),
(5, 'Thabo Ndlefe', 10.0, 100000, 'Ordinary'),
(6, 'Sarah Botha', 9.0, 90000, 'Ordinary'),
(7, 'Dr. Ahmed Kara', 8.0, 80000, 'Preferential'),
(8, 'Naledi Zulu', 7.0, 70000, 'Ordinary'),
(9, 'Michael Roberts', 6.0, 60000, 'Ordinary'),
(10, 'Dr. Vikram Chetty', 4.0, 40000, 'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

Figure M3.5 — SQL backup header and 'staff' table dump, including national ID and salary fields

- The dump also contained a 'shareholders' table: 10 records with shareholder name, share percentage, shares held, and share class — covering named doctors and corporate/trust entities.

```
--
-- Table structure for table 'shareholders'
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`, `shareholder_name`, `share_percent`, `shares_held`, `share_class`) VALUES
(1, 'Dr. Rajesh Naidoo', 18.0, 180000, 'Ordinary'),
(2, 'Cedar Health Holdings (Pty) Ltd', 15.0, 150000, 'Ordinary'),
(3, 'Dr. Johan van der Merwe', 12.0, 120000, 'Ordinary'),
(4, 'Reddy Family Trust', 11.0, 110000, 'Ordinary'),
(5, 'Thabo Ndlefe', 10.0, 100000, 'Ordinary'),
(6, 'Sarah Botha', 9.0, 90000, 'Ordinary'),
(7, 'Dr. Ahmed Kara', 8.0, 80000, 'Preferential'),
(8, 'Naledi Zulu', 7.0, 70000, 'Ordinary'),
(9, 'Michael Roberts', 6.0, 60000, 'Ordinary'),
(10, 'Dr. Vikram Chetty', 4.0, 40000, 'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

Figure M3.6 — 'staff' table (continued) and 'shareholders' table dump showing ownership percentages and share classes

- The 'j.malik' username from F5 was confirmed in the dump as Jameel Malik, IT Systems Administrator — tying the metadata leak directly to a real employee record.

Impact

This is the most severe finding of the engagement. An attacker requires no authentication or exploitation skill beyond discovering a directory path to obtain a complete dump of hospital staff PII (including national ID numbers and salaries) and confidential corporate shareholder/ownership data. This exposes the organisation to identity theft risk for employees, internal compensation disputes, and disclosure of sensitive ownership structure.

3.4 Supplementary Testing — Staff Login Portal

For comparison and completeness, the Staff Login portal (/staff/login.php) was tested using the same methodology applied to the Patient Portal in Milestone 1: page-source review, SQL injection payloads, and username-enumeration analysis via error messages.

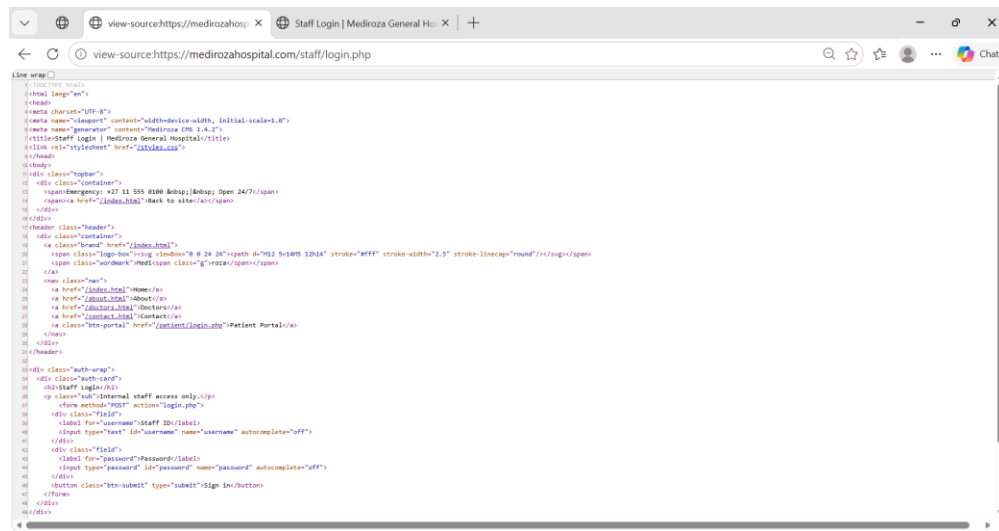


Figure S.1 — View-source of the Staff Login page (field labelled 'Staff ID', plain POST form, no CSRF token)

F6 — Staff Login Portal — Resistant to Tested Attacks (Positive Control)

Risk Rating: Informational

Evidence

- SQL injection payloads tested: admin'--, 'OR '1'=1, 'OR 1=1--, 'OR 1=1#, admin'#, " OR "1"="1, 'OR 'a'='a — all returned the identical generic message "Invalid username or password".
- Submitting the known-valid username 'admin' and random/invalid usernames both returned the same generic error, indicating no detectable username enumeration.

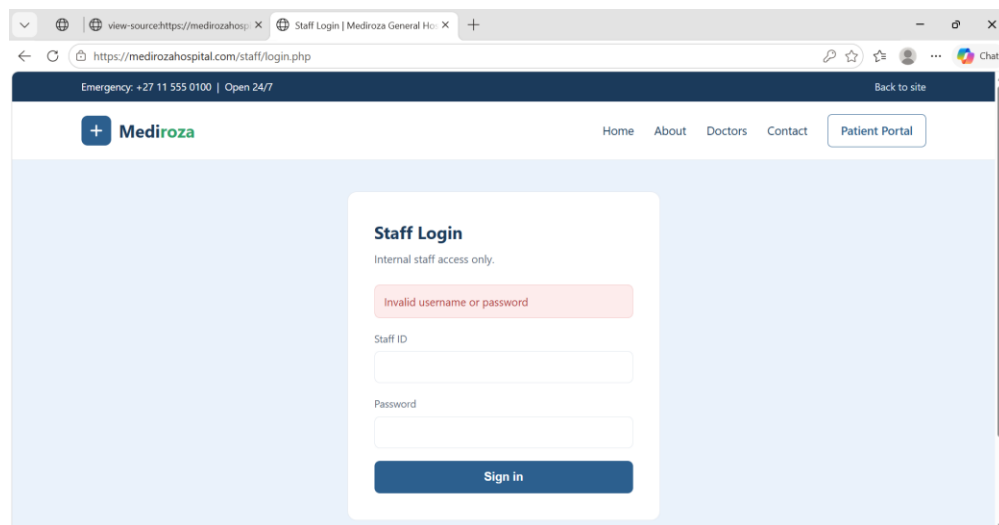


Figure S.2 — Staff Login returning an identical generic error regardless of payload or username tested

Impact

No impact — this is a positive control finding. It indicates the Staff Login form likely uses parameterised queries and a generic, non-differentiating error message, unlike the Patient Portal. This is included to demonstrate that the vulnerabilities in F1 and F4 are implementation-specific rather than systemic across the entire application.

4. Risk Rating

Each finding was rated using a qualitative Likelihood × Impact model, consistent with industry-standard approaches (e.g. OWASP Risk Rating Methodology). Ratings reflect risk to Mediroza General Hospital as of the date of this assessment.

ID	Finding	Likelihood	Impact	Overall Risk
F1	SQL Injection — Auth Bypass (Patient Portal)	High	Critical	Critical
F2	Exposed DB Backup (/old/ directory)	High	Critical	Critical
F3	Weak Passwords on Patient PDF Reports	Medium	High	High
F4	Username Enumeration (Patient Portal)	High	Low	Medium
F5	Sensitive Metadata in PDFs	Medium	Medium	Medium
F6	Staff Login — Resistant to Tested Attacks	—	—	Informational

5. Recommendations and Remediation

F1 — SQL Injection / Authentication Bypass

- Rewrite all database queries in the Patient Portal authentication flow to use parameterised queries / prepared statements. Do not concatenate user input into SQL strings.
- Apply the same remediation proactively across all other forms and endpoints in the application, not only those tested in this engagement.
- Implement a Web Application Firewall (WAF) rule set tuned to detect and block common SQL injection payloads as a defence-in-depth measure.

F2 — Exposed Database Backup

- Immediately remove the /old/ directory and mediroza_db_backup_2019.sql from the public web root.
- Store all backups outside the web-accessible directory structure, with access restricted to authorised administrative personnel only.
- Disable directory listing (autoindex) on the web server for all directories by default.
- Conduct an audit of the web root for any other legacy/forgotten files left over from the 2019 migration referenced in the backup's internal comment.
- Rotate credentials and notify affected staff and shareholders in line with the organisation's data breach response procedure, given the exposure of national ID numbers and compensation data.

F3 — Weak PDF Passwords

- Replace user-memorable passwords with system-generated, high-entropy passwords for any password-protected confidential document.
- Where possible, move away from PDF password protection as the sole control and instead deliver reports through an authenticated patient portal session, with the PDF itself unprotected but access-gated.
- Enforce a minimum password complexity policy within the Mediroza CMS reporting module if user-set passwords are retained.

F4 — Username Enumeration

- Standardise authentication error messages across all login forms to a single generic message (e.g. "Invalid username or password"), matching the behaviour already correctly implemented on the Staff Login portal (see F6).
- Ensure response timing is also consistent between valid and invalid username submissions to prevent timing-based enumeration.

F5 — Metadata Disclosure

- Strip or sanitise document metadata (Author, Comments, Producer) before any PDF is generated for external distribution to patients.
- Review internal processes to ensure operational notes (e.g. migration/backup notes) are never placed in fields that ship with patient-facing documents.

General Recommendations

- Implement rate-limiting, account lockout, or CAPTCHA on all authentication endpoints to slow automated attacks.
- Add CSRF tokens to all state-changing forms, including both login forms.
- Conduct regular, scheduled penetration testing and code review, particularly after site migrations or CMS upgrades.

- Establish a formal vulnerability disclosure and patch management process.

— *End of Report* —